

SESSION 10 – AUTHORIZATION

1. Lý thuyết

Authorization là chức năng dùng để kiểm soát quyền truy cập của người dùng trong hệ thống. Sau khi người dùng đăng nhập thành công, hệ thống không chỉ xác định người dùng là ai mà còn kiểm tra người dùng đó có quyền thực hiện chức năng hay không.

Trong website thương mại điện tử, không phải tài khoản nào cũng có quyền giống nhau. Tài khoản quản trị viên được phép quản lý sản phẩm, còn tài khoản khách hàng chỉ được phép xem sản phẩm, thêm vào giỏ hàng và đặt hàng. Vì vậy, chức năng phân quyền là cần thiết để bảo vệ dữ liệu và hạn chế người dùng thông thường truy cập vào các chức năng quản trị.

Authorization giúp hệ thống hoạt động an toàn hơn, đảm bảo mỗi người dùng chỉ được sử dụng đúng chức năng theo vai trò của mình.

2. Nội dung thực hiện

Trong session này, hệ thống được triển khai chức năng phân quyền người dùng theo vai trò. Hai vai trò chính được sử dụng là **ADMIN** và **CUSTOMER**.

Tài khoản **ADMIN** có quyền truy cập vào trang quản trị và thực hiện các chức năng quản lý sản phẩm như thêm sản phẩm, sửa sản phẩm và xóa sản phẩm. Đây là tài khoản dành cho người quản lý hệ thống.

Tài khoản **CUSTOMER** là tài khoản khách hàng thông thường. Người dùng thuộc vai trò này chỉ có thể xem sản phẩm, thêm sản phẩm vào giỏ hàng và đặt hàng. **CUSTOMER** không được phép truy cập trang quản trị hoặc thực hiện các thao tác thêm, sửa, xóa sản phẩm.

Ở phía backend, các API quan trọng như thêm sản phẩm và xóa sản phẩm được bảo vệ bằng chức năng kiểm tra quyền. Khi người dùng gửi yêu cầu, hệ thống sẽ kiểm tra token đăng nhập và vai trò của người dùng. Nếu người dùng có vai trò **ADMIN**, hệ thống cho phép thực hiện thao tác. Nếu không phải **ADMIN**, hệ thống sẽ từ chối yêu cầu.

Ở phía frontend, trang quản lý sản phẩm cũng được giới hạn quyền truy cập. Chỉ người dùng có vai trò **ADMIN** mới được phép vào trang quản trị. Nếu tài khoản **CUSTOMER** cố gắng truy cập, hệ thống sẽ không cho phép sử dụng chức năng này.

3. Lý thuyết áp dụng

Lý thuyết được áp dụng trong session này là **RBAC – Role-Based Access Control**, nghĩa là kiểm soát quyền truy cập dựa trên vai trò của người dùng.

Với **RBAC**, mỗi người dùng trong hệ thống sẽ được gán một vai trò nhất định. Dựa vào vai trò đó, hệ thống sẽ quyết định người dùng được phép hoặc không được phép thực hiện một chức năng.

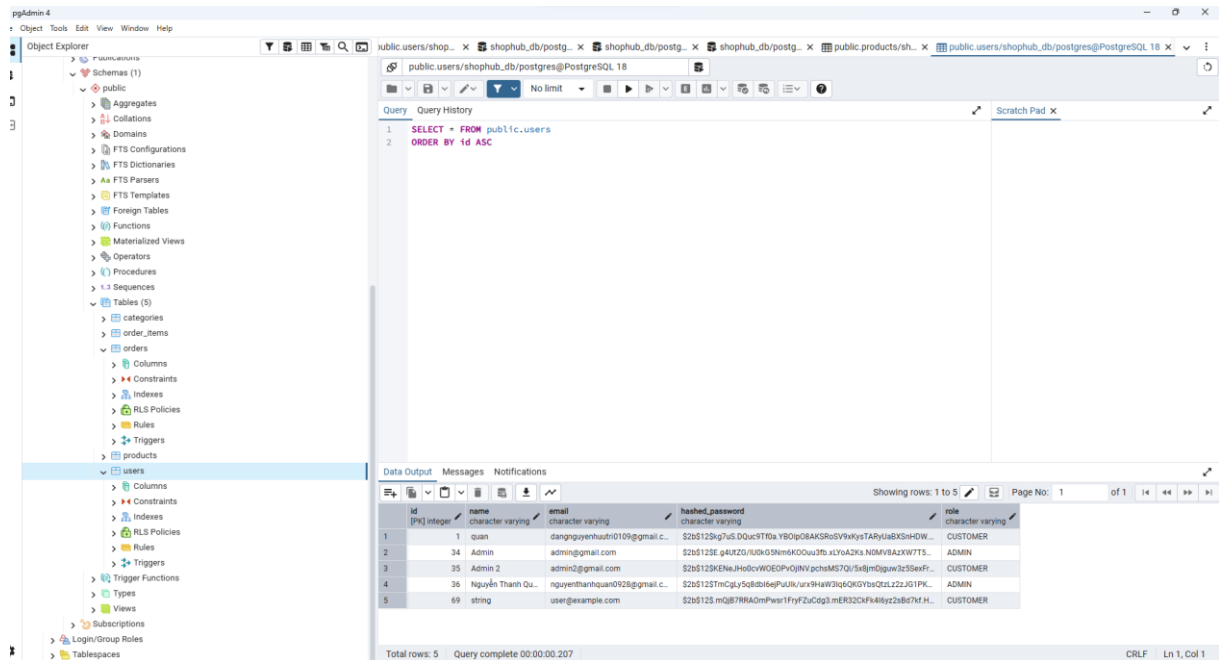
Trong hệ thống ShopHub, **RBAC** được áp dụng như sau:

- **ADMIN:** được phép quản lý sản phẩm, bao gồm thêm, sửa và xóa sản phẩm.

- **CUSTOMER:** chỉ được phép sử dụng các chức năng mua hàng, không được quyền quản trị sản phẩm.

Việc áp dụng RBAC giúp hệ thống phân quyền rõ ràng, dễ quản lý và tăng tính bảo mật. Đây là mô hình phân quyền phổ biến trong các hệ thống website có nhiều loại người dùng khác nhau.

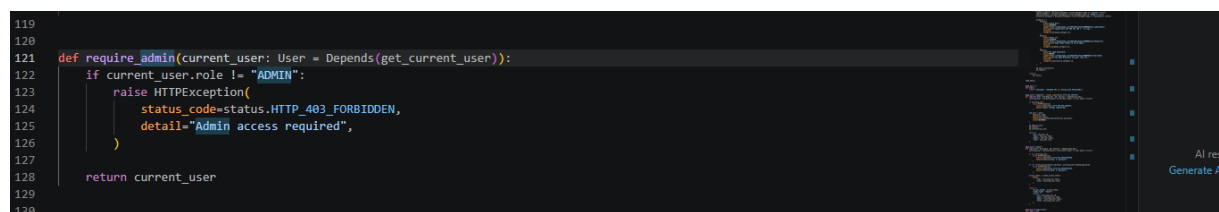
4. Minh chứng



Hình 10.1. Tài khoản người dùng có trường vai trò

Giải thích:

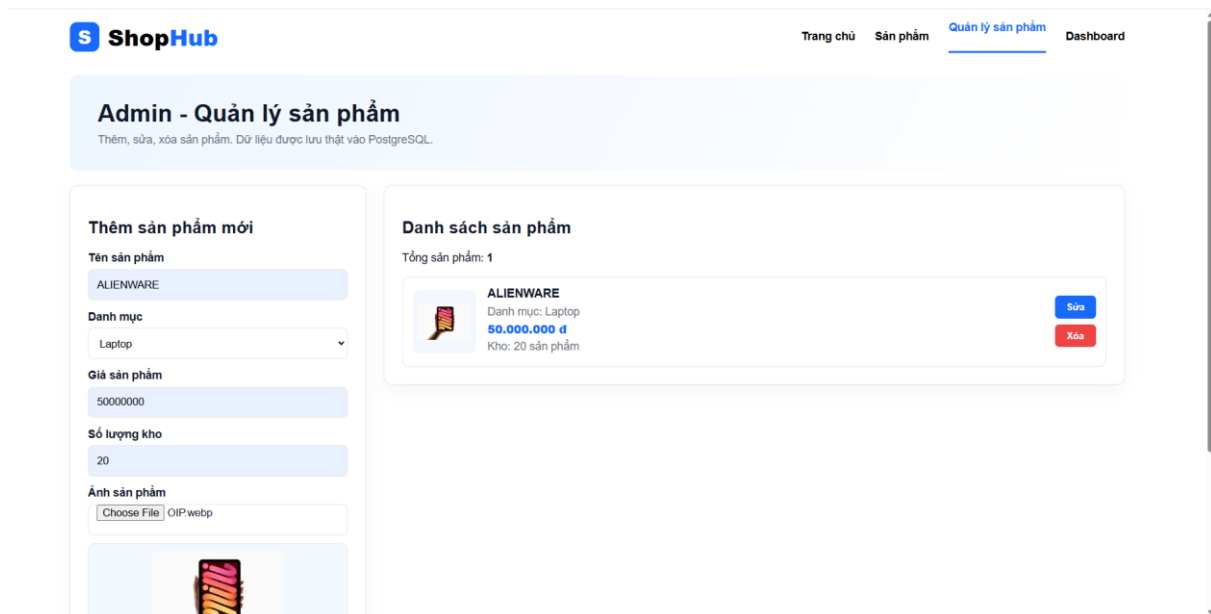
Hình 10.1 cho thấy hệ thống đã bổ sung trường `role` để xác định vai trò của từng tài khoản. Thông qua trường này, hệ thống có thể phân biệt tài khoản ADMIN và CUSTOMER. Đây là cơ sở để thực hiện chức năng phân quyền người dùng.



Hình 10.2. Code kiểm tra quyền ADMIN ở backend

Giải thích:

Hình 10.2 minh chứng backend đã có chức năng kiểm tra quyền người dùng. Khi người dùng gửi yêu cầu thêm hoặc xóa sản phẩm, hệ thống sẽ kiểm tra vai trò của tài khoản. Nếu tài khoản là ADMIN, hệ thống cho phép thực hiện. Nếu không phải ADMIN, hệ thống sẽ từ chối yêu cầu.



Hình 10.3. ADMIN thêm sản phẩm thành công

Giải thích:

Hình 10.3 cho thấy tài khoản ADMIN có quyền thực hiện chức năng thêm sản phẩm. Sau khi gửi yêu cầu hợp lệ, sản phẩm mới được thêm vào hệ thống và lưu vào database. Điều này chứng minh chức năng phân quyền đã hoạt động đúng đối với tài khoản quản trị viên.

5. Kết quả đạt được

Sau khi hoàn thành Session 10, hệ thống đã triển khai được chức năng phân quyền người dùng theo vai trò. Người dùng được chia thành hai nhóm chính là ADMIN và CUSTOMER, mỗi nhóm có quyền sử dụng hệ thống khác nhau.

Tài khoản ADMIN có thể truy cập trang quản trị và thực hiện các thao tác quản lý sản phẩm như thêm, sửa và xóa sản phẩm. Trong khi đó, tài khoản CUSTOMER chỉ có thể sử dụng các chức năng dành cho khách hàng và không được phép thao tác vào chức năng quản trị.

Các API quan trọng ở backend đã được bảo vệ bằng cơ chế kiểm tra quyền. Nếu người dùng không có vai trò ADMIN, hệ thống sẽ từ chối yêu cầu. Bên cạnh đó, frontend cũng được bổ sung chức năng giới hạn truy cập trang quản trị.

Nhờ chức năng Authorization, hệ thống ShopHub trở nên an toàn và chuyên nghiệp hơn. Việc phân quyền giúp bảo vệ dữ liệu sản phẩm, hạn chế người dùng thông thường can thiệp vào chức năng quản trị và đảm bảo hệ thống hoạt động đúng theo vai trò của từng người dùng.